SOFTWARE DESIGN ANALYSIS REPORT

A. Project Details

Project title: **Digital Health Record Management System (DHRMS)**

Team/roll numbers: Abhinav Singh (202401100200014), Abhinav Pathak (202401100200013), Abhishek Kumar Verma (202401100200015), Abhishek Yadav (202401100200016)

Project objective (2-3 lines): To design and implement a secure, centralized electronic healthcare platform managing patient longitudinal records, diagnostic reports, and prescriptions with fine-grained patient consent and auditability.

Technology stack: React, Node.js/Express, PostgreSQL 16, Redis 7, S3 Encrypted Object Store, HL7 FHIR R5, HTTPS/TLS.

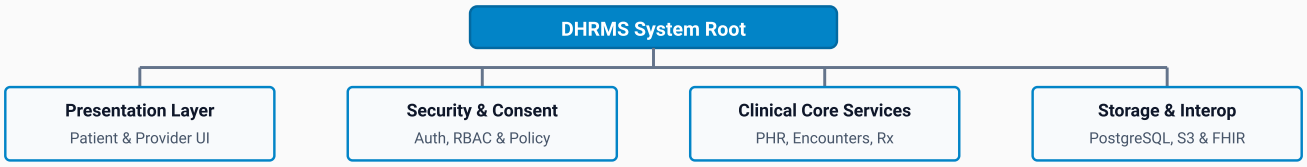
B. Module Identification and Modularization

Total number of modules: **11 Modules** (Identity/Auth, PHR, RBAC, Consent, Clinical Encounters, Diagnostics, Prescriptions, Doc Storage, Interoperability, Audit, Admin).

Modularization Rationale: The system is decomposed along clinical and security boundaries to enforce the principle of least privilege, isolate regulated medical records from user account lifecycle management, guarantee independent scalability of FHIR interoperability pipelines, and ensure tamper-resistant audit tracking.

Module ID	Module Name	Main Responsibility	Inputs/Outputs	Depends On
M1	Identity & Auth (IAM)	User registration, login session, MFA validation, JWT issuing	In: Credentials / Out: JWT token	None (Core)
M2	Consent Management	Evaluate, grant, verify, and revoke provider access directives	In: Consent rules / Out: Permit status	M1, M3
M3	Patient Health Records (PHR)	Longitudinal clinical history, allergies, condition summaries	In: Patient ID / Out: Patient records	M1, M2
M4	Clinical Encounters & Rx	Record consultations, vital signs, diagnoses, and prescriptions	In: Clinical notes / Out: Encounter obj	M2, M3

Module Hierarchy / Decomposition Diagram



C. Design Strategy

Selected strategy: ☑ Top-Down ☐ Bottom-Up ☐ Hybrid

Justification: A Top-Down strategy was chosen because healthcare compliance requires system-wide security, consent boundaries, and role-governed workflows to be mathematically established at the architectural level before implementing individual data stores. Designing top-down ensured that authorization and data masking were integral to all subsystems rather than retrofitted.

Evidence: We initiated design from the high-level patient-provider clinical encounter lifecycle down to atomic service APIs. Global security policies were decomposed into distinct micro-operations (e.g., verifying active consent prior to invoking medical document retrieval services).

D. Design Approach

Selected approach: ☐ Function-Oriented ☑ Object-Oriented ☐ Mixed

Justification: The medical domain exhibits rich, highly coupled real-world entities (Patient, Clinician, DiagnosticReport, Prescription, ConsentDirective) characterized by clear state lifecycles and encapsulation requirements. Object-Oriented design provides strong encapsulation of medical record integrity rules and enables polymorphic handling of standardized FHIR R5 resources.

E. Coupling Analysis

Evaluated key module-to-module interactions to ensure loose coupling:

Module Pair	Interaction / Shared Data	Coupling Type	How to Reduce Dependency
Encounter Mgmt ↔ Consent Mgmt	Passes `patient_id` and `doctor_id` to verify active access directive.	**Data Coupling** (Low/Ideal)	Pass only minimal scalar IDs rather than full clinical context objects.
PHR Service ↔ Diagnostic Store	Requests diagnostic file metadata and signed read URI via report ID.	**Data Coupling** (Low)	Use pre-signed S3 temporary URLs; decouple storage engine details from PHR.
All Services ↔ Audit Logger	Emits structured JSON security events and authorization failure payloads.	**Stamp / Message** (Loose)	Asynchronous fire-and-forget message bus queue prevents caller blocking.

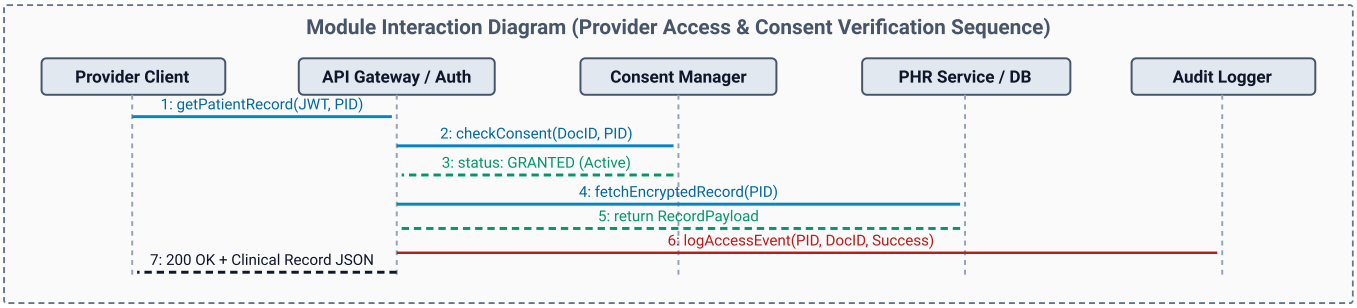
F. Cohesion Analysis

For each major module, we evaluated its internal task focus. High functional cohesion was maintained by confining each module strictly to a single business capability:

Module	Single Main Responsibility	Cohesion Type	Improvement / Guardrail
Identity & Auth (M1)	Managing user authentication tokens, credential validation, and MFA state.	**Functional Cohesion** (Highest level)	Keep user demographic profile management delegated entirely to PHR.
Consent Manager (M2)	Evaluating and recording patient-granted temporal access rules and revocations.	**Functional Cohesion** (Highest level)	Isolate consent rules from clinical diagnosis logic; return simple boolean grant.
Medical Document (M8)	File validation, SHA-256 hash computation, and encrypted object store IO.	**Sequential Cohesion** (High)	Ensure cryptographic hashing immediately feeds into repository metadata storage.
Audit & Compliance (M10)	Chronological ingestion and append-only recording of system access logs.	**Communicational** (High)	Isolate audit storage to immutable write-only database tables.

G. Module Interaction and Design Quality

Sequence Diagram: Demonstrating how major modules exchange messages during a provider record access request governed by patient consent validation.



Design Quality & Security Validation: The sequence demonstrates strict non-bypassable policy enforcement: access to the Patient Health Record store is mediated by the Gateway verifying active consent tokens. Even for authorized clinicians, requests without a valid directive fail at step 3, logging an audit violation without clinical data exposure.

H. Overall Design Quality & Evaluation

Quality Metric	Design Decision	Resulting Engineering Benefit
Modularity	11 discrete single-responsibility service subsystems.	Independent testability and deployment velocity.
Security & Integrity	Consent check intercepts, SHA-256 file hashing, MFA.	Zero-trust access control with regulatory HIPAA/GDPR compliance.
Interoperability	Standardized HL7 FHIR Release 5 REST interface.	Seamless electronic data interchange with third-party hospitals.
Reliability	ACID relational storage + immutable append-only logs.	Zero record loss; complete non-repudiation of clinical actions.